



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Tusk Infostealer (CyberDefenders)

Análisis de Threat Intelligence de la campaña Tusk (Kaspersky GERT), identificando TTPs, IOCs y flujo de criptomonedas de tres subcampanas que distribuyen los infostealers StealC y Danabot.

Sebastian David
Torres Reyes

Escenario:

Analyze threat intelligence and malware configuration to identify TTPs, extract IOCs, and track cryptocurrency flow of the Tusk Infostealer campaign.

Herramientas utilizadas:

- VirusTotal
- Kaspersky Threat Intelligence Portal

Resumen:

Este informe documenta el análisis de inteligencia de amenazas y configuración de malware de la campaña Tusk Infostealer, identificada por el equipo de Kaspersky GERT como una operación compuesta por múltiples subcampañas orquestadas por ciberdelincuentes de habla rusa. El nombre "Tusk" hace referencia al término "Mammoth" (mamut), jerga utilizada por los atacantes en sus mensajes de log para referirse a las víctimas.

La campaña opera suplantando plataformas legítimas (una plataforma de gestión de DAOs sobre MultiversX, un videojuego MMO y un traductor con IA) mediante sitios web falsos que distribuyen un downloader inicial alojado en Dropbox. Este downloader, basado en aplicaciones Electron, utiliza un archivo de configuración (config.json) con URLs codificadas en base64 y una contraseña de descompresión para descargar y ejecutar payloads de segunda etapa.

El análisis identificó el uso de HijackLoader para inyectar código malicioso en procesos legítimos del sistema (cmd.exe, explorer.exe, OpenWith.exe) como técnica de evasión, derivando en la ejecución de los infostealers StealC y Danabot, así como de un malware de tipo Clipper desarrollado en Go que intercepta y sustituye direcciones de criptomonedas copiadas al portapapeles para desviar fondos hacia las wallets del atacante.

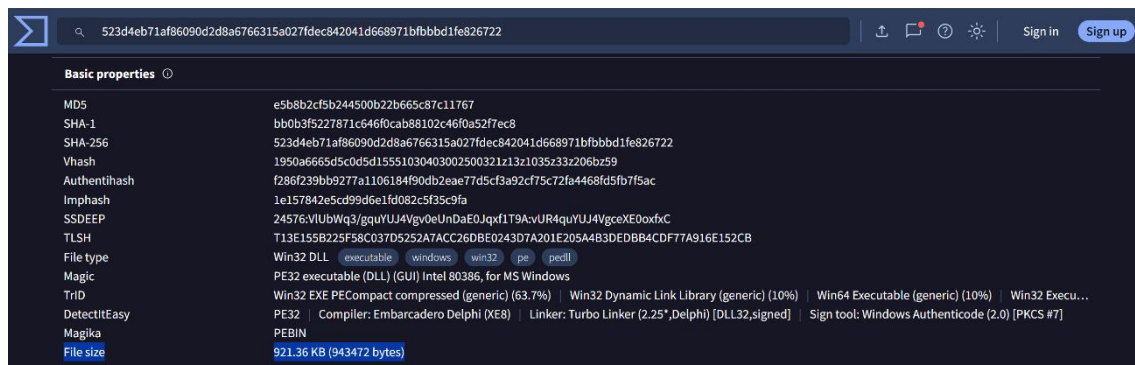
Se extrajeron indicadores de compromiso clave, incluyendo dominios maliciosos (tidyme[.]io, runeonlineworld[.]io, voico[.]io), direcciones IP de servidores C2 vinculados a StealC, y tres direcciones de wallets de criptomonedas (BTC y ETH) asociadas a la operación, de las cuales dos registraron actividad financiera confirmada durante el período analizado.

Este análisis permite comprender las tácticas, técnicas y procedimientos (TTPs) empleados por el actor de amenaza, así como rastrear el flujo de fondos de la campaña, información de utilidad para la detección, atribución y respuesta ante este tipo de amenazas de robo de información con motivación financiera.

P1: In KB, what is the size of the malicious file?

R: 921.36

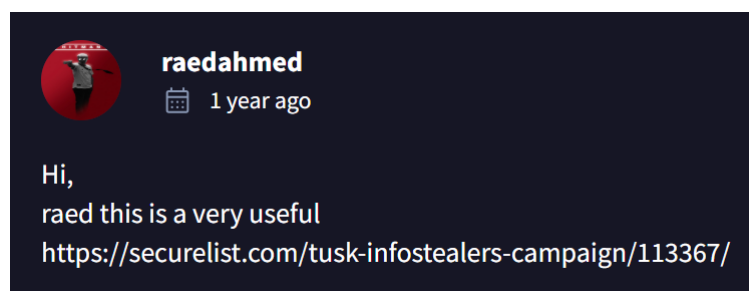
Se investigó el hash MD5 del archivo malicioso en VirusTotal donde 42 motores de antivirus lo detectaron como trojan o downloader, además etiquetó al malware con las familias jaik, rugmi y malgent. En los detalles se verificó el tamaño de 921.36 KB del archivo.



P2: What word do the threat actors use in log messages to describe their victims, based on the name of an ancient hunted creature?

R: Mammoth

En los comentarios de la comunidad del reporte de VirusTotal un usuario proporcionó un enlace útil para encontrar el término que utilizan los atacantes en este incidente.



El reporte hecho por SecureList de Kaspersky de la campaña Tusk Infostealer detalla que esta está compuesta por múltiples subcampañas orquestadas por ciberdelincuentes de habla rusa que alojan un downloader que tiene como función la distribución de programas maliciosos de robo de información (Danabot y StealC).

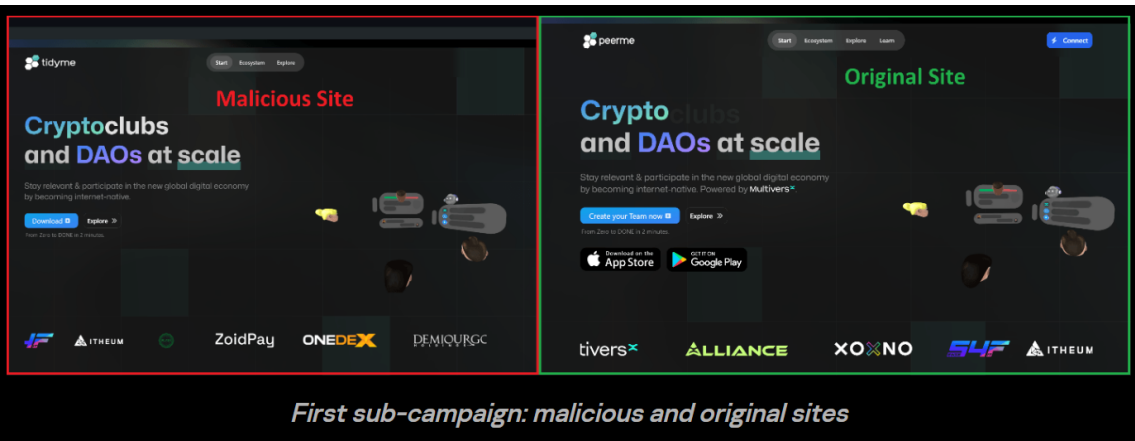
Estos ciberdelincuentes de habla rusa utilizan el término coloquial “Mammoth” para referirse a sus víctimas.

Мамонт открыл lanzador...	Mammoth abrió el lanzador...
Мамонт свернул лаунчер...	Mammoth hizo colapsar el lanzador...
Мамонт закрыл lanzador...	Mammoth cerró el lanzador...

P3: The threat actor set up a malicious website to mimic a platform designed for creating and managing decentralized autonomous organizations (DAOs) on the MultiversX blockchain (peerme.io). What is the name of the malicious website the attacker created to simulate this platform?

R: tidyme[.]io

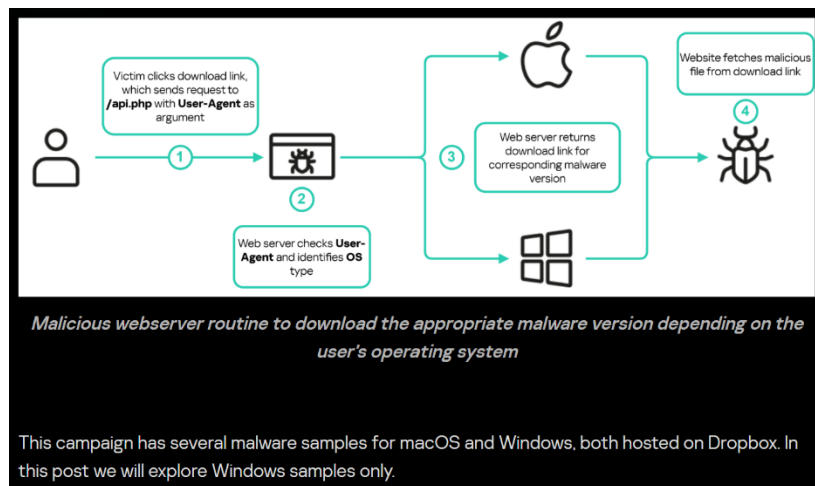
En el reporte analizado anteriormente también se detalla que la primera subcampaña tuvo como objetivo suplantar la plataforma peerme.io creando el sitio web malicioso tidyme[.]io.



P4: Which cloud storage service did the campaign operators use to host malware samples for both macOS and Windows OS versions?

R: Dropbox

La primera subcampaña, que tuvo como objetivo el spoofing de peerme.io, alojó las muestras de malware en la nube de Dropbox.



Malicious webserver routine to download the appropriate malware version depending on the user's operating system

This campaign has several malware samples for macOS and Windows, both hosted on Dropbox. In this post we will explore Windows samples only.

P5: The malicious executable contains a configuration file that includes base64-encoded URLs and a password used for archived data decompression, enabling the download of second-stage payloads. What is the password for decompression found in this configuration file?

R: newfile2024

Según Kaspersky, el ejecutable malicioso contiene un archivo llamado config.json que incluye URLs codificadas en base64 además de la contraseña de descompresión utilizada para la descarga de los payloads de la segunda etapa.

```
1 {
2   "archive": "aHR0cHM6Ly93d3cuZHZjcGJveC5jb20vc2NsL2ZpL2N3NmpzYnA5ODF4eTg4dHprM29ibS91cGRhdG
3   "password": "newfile2024",
4   "bytes": "aHR0cDovL3Rlc3Rsb2FkLnB5dGhvbmcueXdoZXJlLnNvbS9nZXRIeXRlc3Ym"
5 }
```

P6: What is the name of the function responsible for retrieving the field archive from the configuration file?

R: downloadAndExtractArchive

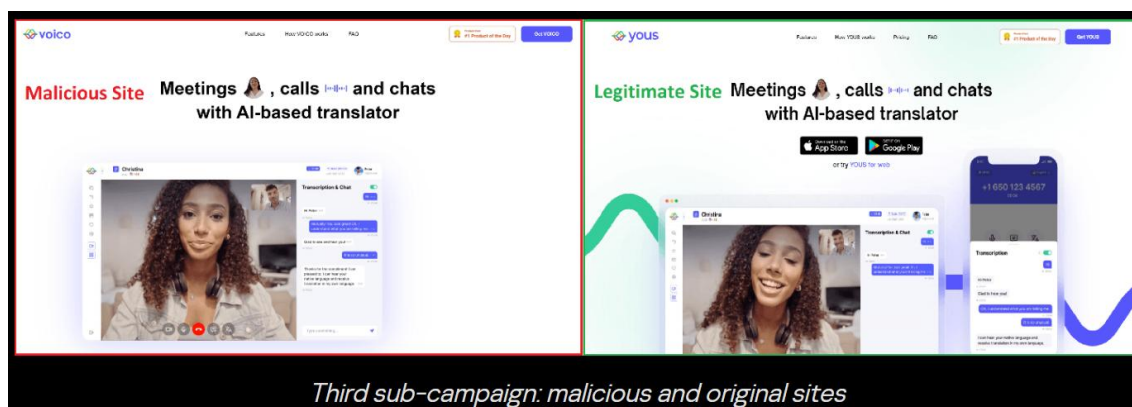
En el reporte también se menciona un archivo llamado preload.js encargado de la funcionalidad principal del downloader. En este archivo JS existen dos funciones (downloadAndExtractArchive y loadFile) donde la función downloadAndExtractArchive se encarga de recuperar el valor del campo 'archive' contenido en config.json, que es un enlace de Dropbox codificado que posteriormente se decodifica y se guarda en la ruta "%TEMP%/archive-<RANDOM_STRING>". Este archivo descargado es un archivo RAR que contiene

múltiples archivos EXE que se ejecutan una vez se extraen utilizando la contraseña contenida en el campo "password" del archivo de configuración.

P7: In the third sub-campaign carried out by the operators, the attacker mimicked an AI translator project. What is the name of the legitimate translator, and what is the name of the malicious translator created by the attackers?

R: Yous.ai, voico.io

En la tercera subcampaña el atacante nuevamente suplanta la identidad de un sitio web [yous.ai](#) utilizado para la traducción de IA. El sitio web malicioso llamado [voico\[.\]io](#), al igual que las dos primeras subcampañas, contiene un enlace que descarga un ejecutable malicioso alojado en la misma nube Dropbox.



P8: The downloader is tasked with delivering additional malware samples to the victim's machine, primarily infostealers like StealC and Danabot. What are the IP addresses of the StealC C2 servers used in the campaign?

R: 46[.]8[.]238[.]240,23[.]94[.]225[.]177

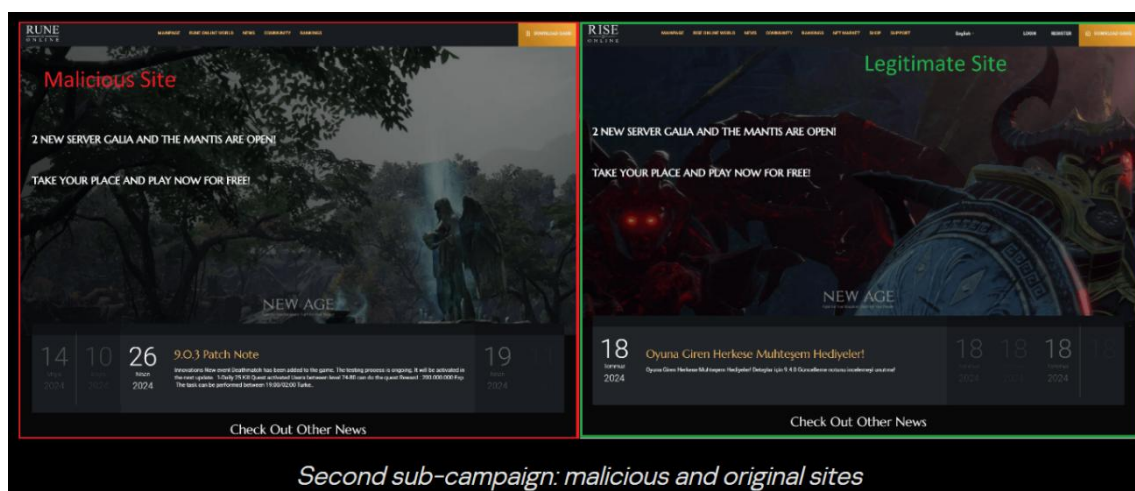
En el apartado de Indicadores de Compromiso (IoC) del reporte realizado por Kaspersky, se muestran las URLs y direcciones IP vinculadas a los servidores C2. Debido a que en esta campaña el objetivo de los atacantes es la distribución de malware como StealC y Danabot, se lograron identificar dos servidores C2 vinculados al infostealer StealC (46[.]8[.]238[.]240 y 23[.]94[.]225[.]177).

Network IoCs	
Domain or IP	Details
46.8.238.240	StealC C2 Server
77.91.77.200	Download madHcCtrl files
23.94.225.177	StealC C2 Server

P9: What is the address of the Ethereum cryptocurrency wallet used in this campaign?

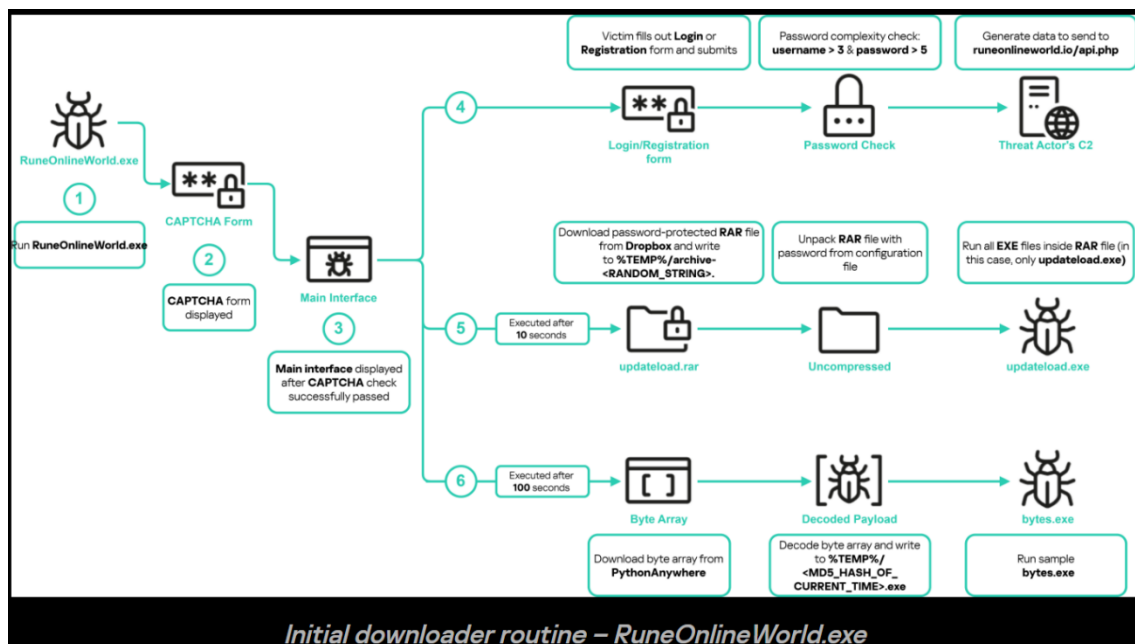
R: 0xaf0362e215Ff4e004F30e785e822F7E20b99723A

En la segunda subcampana el atacante simulaba un sitio web de un juego MMO. El dominio original es riseonlineworld.com y el sitio web malicioso fue llamado runeonlineworld[.]jio.

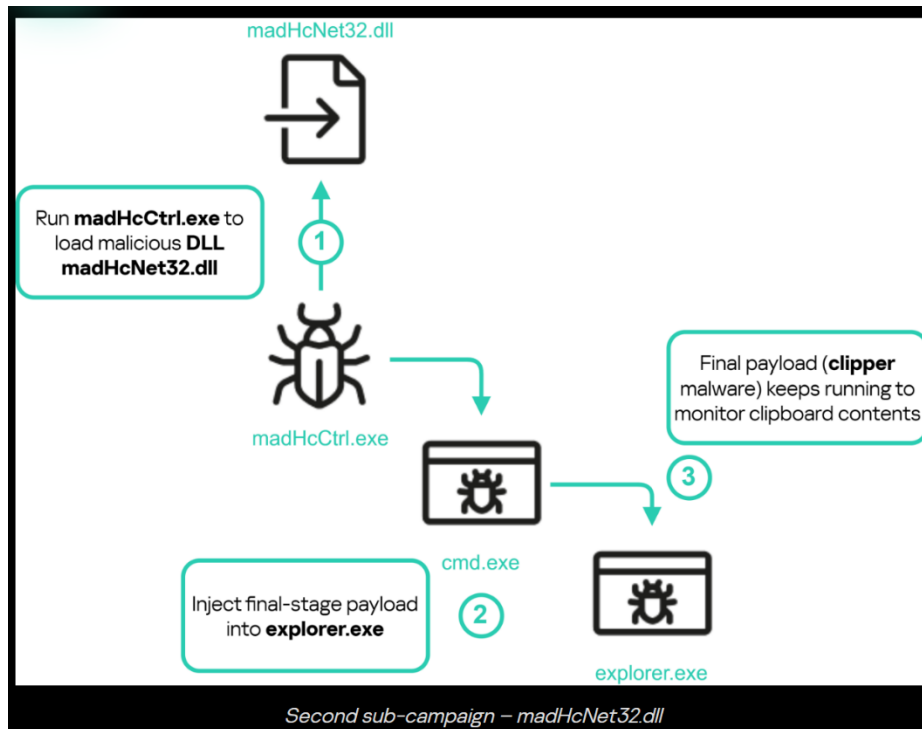


Al igual que la primera subcampana, el programa también contiene un enlace de descarga de malware alojado en Dropbox. Este archivo EXE al ser ejecutado abre un CAPTCHA; tras superar la verificación del CAPTCHA, la víctima ingresa sus credenciales en una página de inicio de sesión falsa y esta información se envía al servidor C2 del atacante. Además, se descarga un archivo RAR que contiene un archivo EXE que se ejecuta una vez se extrae utilizando la contraseña contenida en el campo "password" del archivo de configuración, al igual que en la primera subcampana; en este caso solamente el archivo updateload.exe (primer payload). Este archivo utiliza HijackLoader, que inyecta código malicioso en procesos legítimos (cmd.exe y explorer.exe inicialmente) para evadir la detección;

posteriormente explorer.exe se comunica con los servidores C2 para la distribución de archivos DLL y MSI y la ejecución de estos mediante msixec.exe (para los archivos MSI) y rundll32.exe (para la ejecución de los archivos DLL).



El segundo payload, bytes.exe, también utiliza HijackLoader, que en este caso inyecta código malicioso en cmd.exe, que a su vez inyecta a los procesos explorer.exe y OpenWith.exe. Este último se encargará de la descarga, decodificación e inyección de muestras de malware desde el servidor C2 a otra instancia de OpenWith.exe, con el objetivo final de establecer persistencia tras la creación de una tarea programada llamada FJ_load que ejecutará uno de los archivos descargados, madHcCtrl.exe. Entre estos archivos descargados también se encuentra un archivo malicioso llamado madHcNet32.dll, que será ejecutado por madHcCtrl.exe, el cual también usa HijackLoader para la extracción y ejecución del payload final. Finalmente, madHcCtrl.exe inyecta el payload final en explorer.exe; este payload final es un malware de tipo Clipper diseñado para el robo de información financiera, que intercepta y altera los datos del portapapeles, sustituyendo las direcciones de criptomonedas que se pegan al realizar una transferencia, enviando los fondos directamente al atacante.



En el reporte se detallan las direcciones de monedero de criptomonedas que fueron utilizadas en esta campaña:

- BTC: 1DSWHiAW1iSFYVb86WQQUPn57iQ6W1DjGo
- ETH: 0xaf0362e215Ff4e004F30e785e822F7E20b99723A
- BTC: bc1qqkvqgtpwq6g59xgwr2sccvmudejfxwyl8g9xg0

En el caso de la billetera de criptomonedas Ethereum (ETH) se menciona que estuvo activa del 4 de marzo al 31 de julio y recibió un total de 9.137 ETH (equivalentes aproximadamente a 14 469.12 dólares), y una segunda wallet BTC activa entre el 2 de abril y el 6 de agosto con 0.0209 BTC recibidos.